

QA FIXES LOG

Remediation & Bug Resolution Registry — Vishal Gold

Project	Vishal Gold — B2B/B2C Jewelry App
Prepared For	Vishal Gold QA & Engineering Teams
Prepared By	Senior Development Lead
Version	v1.1
Date	February 25, 2026

Table of Contents

- 1. Fix Priority & Strategy
- 2. Remediation Detail (F-001 to F-008)
- 3. Iteration Status Summary

1. Fix Priority & Strategy

This log documents the systematic remediation of security vulnerabilities (VAPT) and functional defects (QA) identified in the Vishal Gold app. The priority for resolution follows the risk hierarchy: Critical → High → Medium → Low.

2. Remediation Detail

Fix F-001 — PII Migration to Secure Storage

- Severity: Critical
- Impact IDs: VAPT-001, BUG-002

Root Cause

PII fields (Name, Phone, etc.) were previously stored in plaintext SharedPreferences.

Fix Implemented

Migrated all PII to FlutterSecureStorage using the new SecureLocalStorageService. SharedPreferences now only stores non-sensitive JSON blobs.

Modules Modified

lib/services/local_storage_service.dart, lib/providers/auth_provider.dart

Fix F-002 — Server-Side Role Validation

- Severity: Critical
- Impact IDs: VAPT-002

Root Cause

Client implicitly trusted user role from local storage without Firestore verification.

Fix Implemented

Auth init now fetches user role from Firestore profile. Local cache is used only as persistent fallback verified against server record.

Modules Modified

lib/providers/auth_provider.dart, lib/services/firebase_service.dart

Fix F-003 — Admin Gesture Removal

- Severity: Critical
- Impact IDs: VAPT-003, BUG-005

Root Cause

Hidden 3-second logo long-press granted undocumented access to admin login.

Fix Implemented

Removed GestureDetector and related timer logic. Admin access moved to authorized deep-links and whitelisted devices.

Modules Modified

lib/screens/auth/phone_auth_screen.dart

Fix F-004 — OTP Rate Limiting

- Severity: High
- Impact IDs: VAPT-004, BUG-001

Root Cause

Rapid manual triggering of OTP requests was possible, leading to service abuse.

Fix Implemented

Implemented 60-second client-side cooldown timer. Button is disabled and shows remaining countdown after request.

Modules Modified

lib/screens/auth/phone_auth_screen.dart

Fix F-005 — Secure Cart ID Generation

- Severity: High
- Impact IDs: VAPT-005

Root Cause

Cart IDs were generated using predictable timestamp values.

Fix Implemented

Transitioned to cryptographically random UUID v4 identifiers via the uuid package.

Modules Modified

lib/providers/cart_provider.dart

Fix F-006 — ADB Backup & Flag Secure

- Severity: Medium
- Impact IDs: VAPT-016, VAPT-012

Root Cause

Device backup enabled and screenshots permitted on sensitive profile screens.

Fix Implemented

Set `allowBackup='false'` in `Manifest`. Enhanced Cart and Profile screens with `FLAG_SECURE` to prevent screenshots.

Modules Modified

android/app/src/main/AndroidManifest.xml

Fix F-007 — UI Error Sanitization

- Severity: Medium
- Impact IDs: VAPT-017, VAPT-009

Root Cause

Raw exception strings were exposed to users in UI snackbars/dialogs.

Fix Implemented

Implemented generic error messaging for production builds while preserving detailed `kDebugMode` logging for development.

Modules Modified

lib/services/firebase_service.dart, lib/providers/auth_provider.dart

Fix F-008 — Quantity Upper Bound

- Severity: Medium
- Impact IDs: BUG-004

Root Cause

Users could increment product quantity to unreasonable levels.

Fix Implemented

Hard-capped product quantity at 99 in `ProductDetailScreen` with incremental validation.

Modules Modified

lib/screens/product/product_detail_screen.dart

3. Iteration Status Summary

Iteration	Fixes	Critical Rem.	High Rem.	Verification
1	8	0	0	Retest PASS ✓

All Critical and High severity findings identified in initial assessment have been verified as resolved.